universität wien

Ist die DSGVO fit für das KI-Zeitalter?

Univ.-Prof. Dr. Dr. h.c. Christiane Wendehorst, LL.M.

Überblick

1. Das Verhältnis von KI-VO und DSGVO
2. Datenschutz und KI – wo ist das Problem?
3. Aktuelle Reformdiskussion

Das Verhältnis von KI-VO und DSGVO

Zusammenspiel der KI-VO mit anderen Rechtsakten

Bedeutung der Anwendbarkeit der DSGVO (I)

Prinzipien der Datenverarbeitung u.a.:

- **Datenminimierung**
- **Zweckbindung** und
- **Speicherbegrenzung**

Anforderungen der KI-Entwicklung u.a.:

- **Repräsentativität und Vollständigkeit**
- weitgehende **Zweckoffenheit** und
- Verfügbarkeit für **Sekundärnutzungen**

DSGVO bleibt unberührt – mit zwei Ausnahmen

Artikel 2

Anwendungsbereich

[…]

(7) Die Rechtsvorschriften der Union zum Schutz personenbezogener Daten, der Privatsphäre und der Vertraulichkeit der Kommunikation gelten für die Verarbeitung personenbezogener Daten im Zusammenhang mit den in dieser Verordnung festgelegten Rechten und Pflichten. Diese Verordnung berührt nicht die Verordnung (EU) 2016/679 bzw. (EU) 2018/1725 oder die Richtlinie 2002/58/EG bzw. (EU) 2016/680, unbeschadet des Artikels 10 Absatz 5 und des Artikels 59 der vorliegenden Verordnung.

Ausnahme: Verarbeitung besonderer Kategorien von pbD zur Entdeckung und Minimierung von Bias und Diskriminierung

Ausnahme: Verarbeitung von pbD in KI-Reallaboren

Bedeutung der Anwendbarkeit der DSGVO (II)

- **Verbot mit Erlaubnisvorbehalt**, d.h. jegliche Verarbeitung personenbezogener Daten (auch bloße Speicherung) bedarf einer Rechtsgrundlage in Art. 6 DSGVO, z.B. Einwilligung, berechtigte Interessen
- Bei **sensiblen Datenkategorien i.S.d. Art. 9 DSGVO** (vom EuGH sehr weit verstanden) bedarf es zusätzlich eines der eng formulierten Ausnahmetatbestände in Art. 9 Abs. 2

(a) Einwilligung

(b) Erforderlichkeit für Vertrag

[…]

(f) berechtigte Interessen

bei sensiblen Datenkategorien

+

(a) ausdrückliche Einwilligung

[…]

(e) offensichtl. Öffentlichmachung durch Betroffenen

[…]

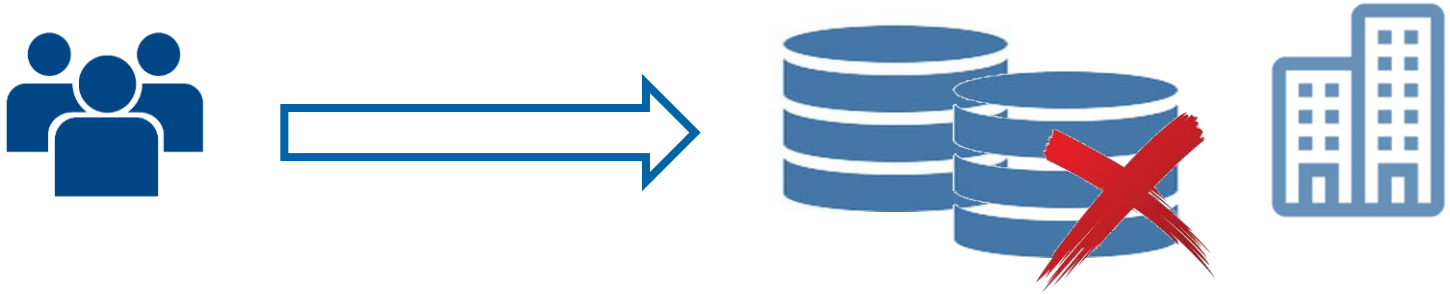
(g) Rechtsvorschrift + erforderlich f. erhebl. öffentl. Interesse

[…]

(j) Rechtsvorschrift + erforderlich für wiss. Forschung etc.

Bedeutung der Anwendbarkeit der DSGVO (III)

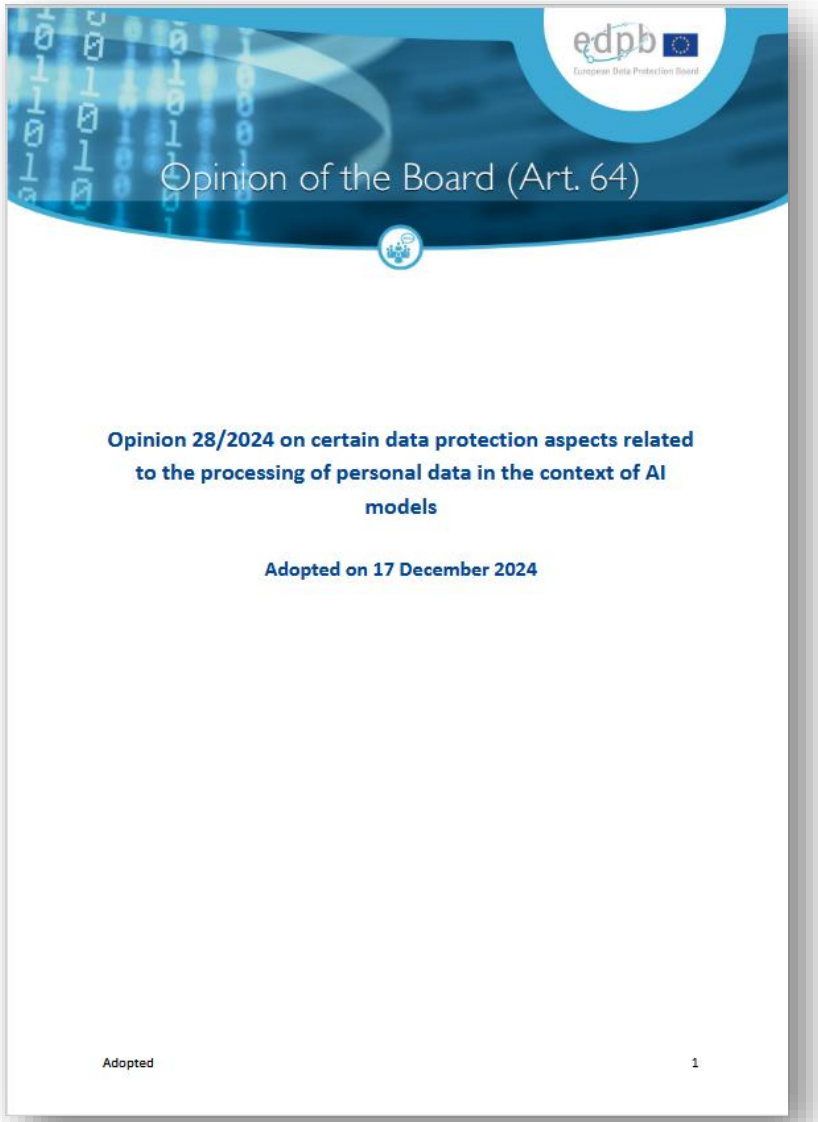
- Betroffene Personen haben sog. **Betroffenenrechte**, z.B.
  - Recht auf **Auskunft** hinsichtlich verarbeiteter personenbezogener Daten
  - Recht auf **Berichtigung** unrichtiger Daten oder
  - Recht auf **Löschung** („Recht auf Vergessenwerden“), z.B. sobald die Daten für den Zweck, für den sie erhoben oder sonst verarbeitet wurden, nicht mehr notwendig sind



Bedeutung der Anwendbarkeit der DSGVO (IV)

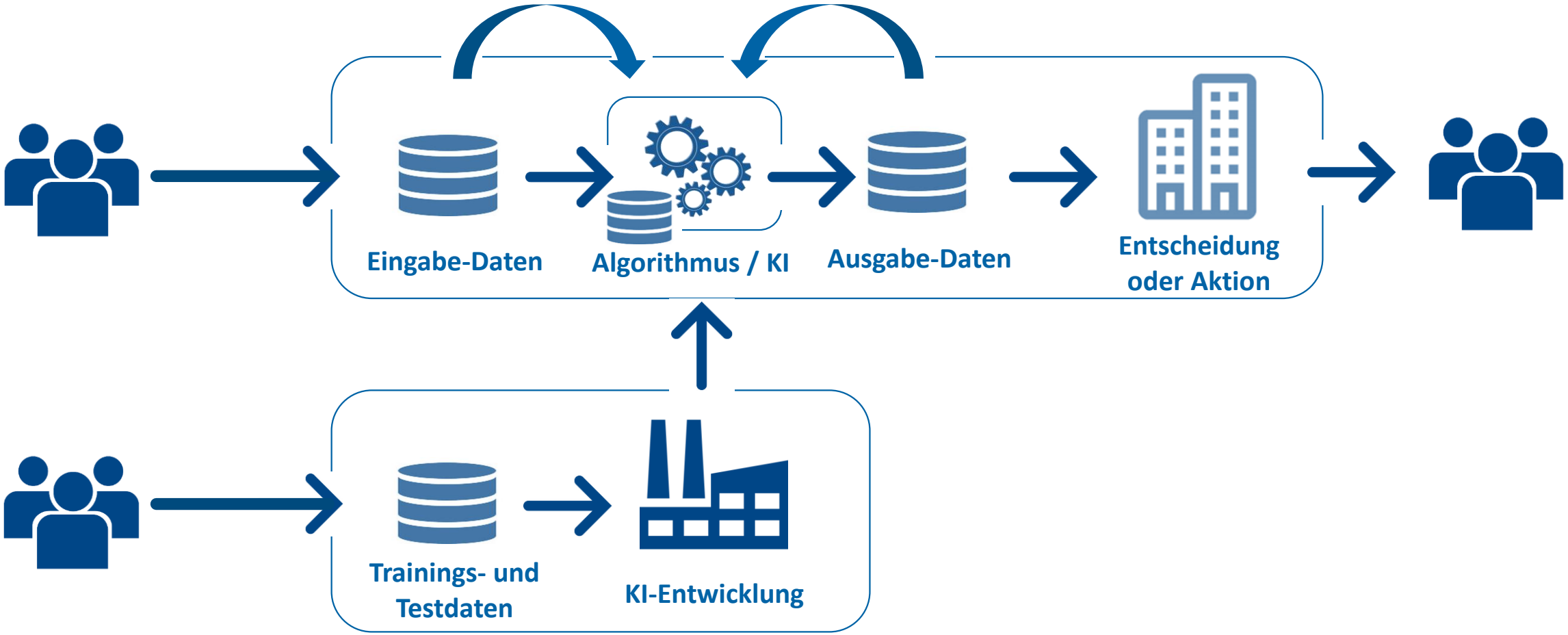
- **Automatisierte Entscheidungen mit** rechtlicher oder ähnlich **schwerwiegender Wirkung**
  - nach Art. 22 DSGVO verboten, sofern nicht ein **Ausnahmegrund** vorliegt (Erforderlichkeit im vertraglichen Kontext, ausdrückliche Einwilligung, Erlaubnis durch Rechtsvorschrift mit angemessenen Maßnahmen)
  - dürfen **nicht auf sensiblen Datenkategorien** beruhen, es sei denn ausdrückliche Einwilligung oder Rechtsvorschrift zur Wahrung eines erheblichen öffentlichen Interesses
  - bedürfen in jedem Fall einer Reihe von **Schutzmaßnahmen** (Recht auf Erwirkung menschlichen Eingreifens, Darlegung des eigenen Standpunkts und Anfechtung der Entscheidung)
  - lösen nach Art. 13-15 DSGVO **Erläuterungspflichten** aus – ähnliches Recht in Art. 86 KI-VO

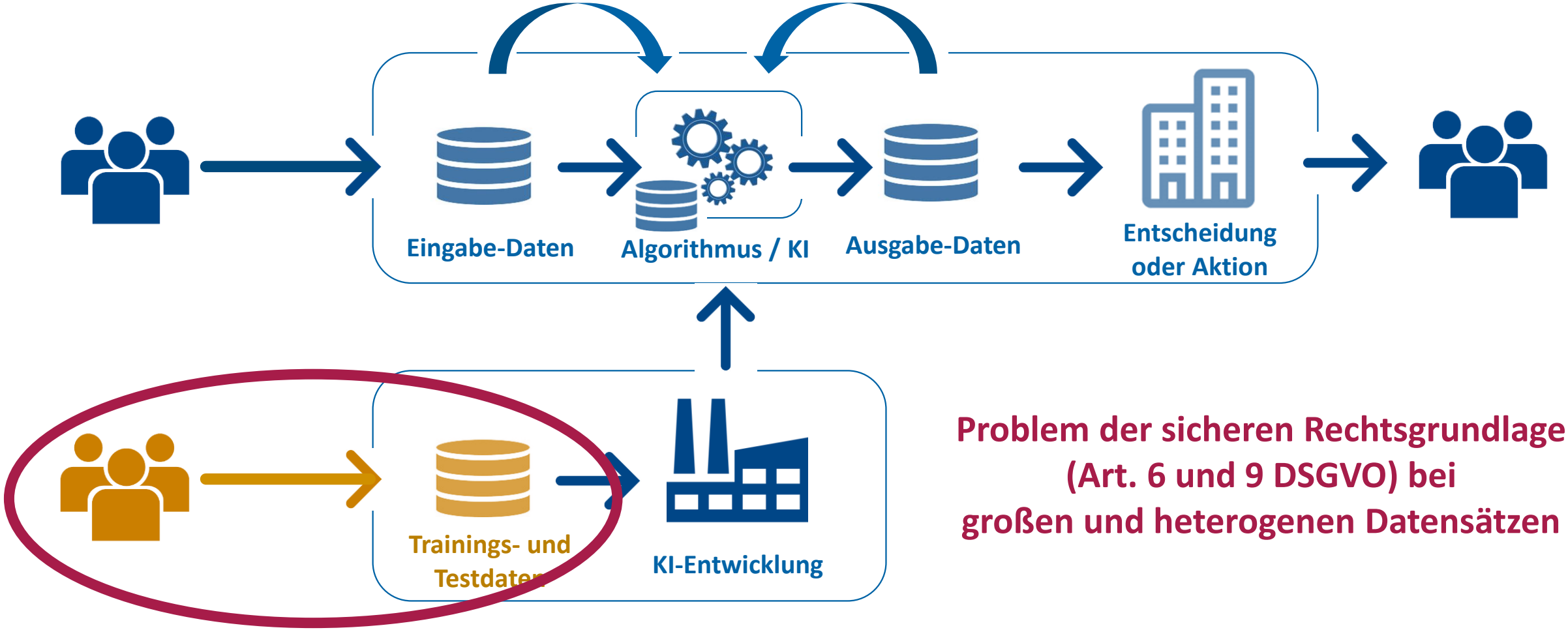
EDPS
EUROPEAN DATA PROTECTION SUPERVISOR
The EU's independent data protection authority
03 June 2024
Generative AI and the EUDPR.
First EDPS Orientations for ensuring data protection compliance when using Generative AI systems.
edps.europa.eu


edpb
European Data Protection Board
Opinion of the Board (Art. 64)
Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models
Adopted on 17 December 2024
Adopted
1

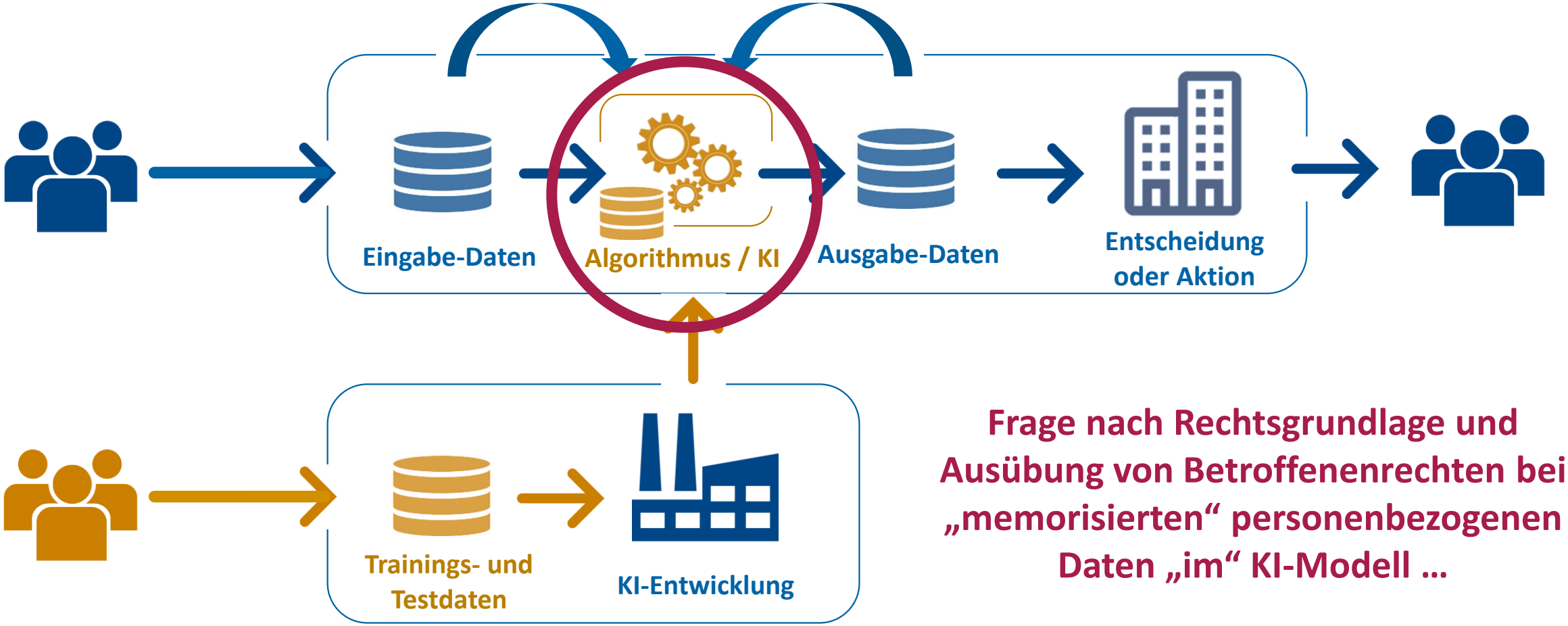
?

Datenschutz und KI – wo ist das Problem?

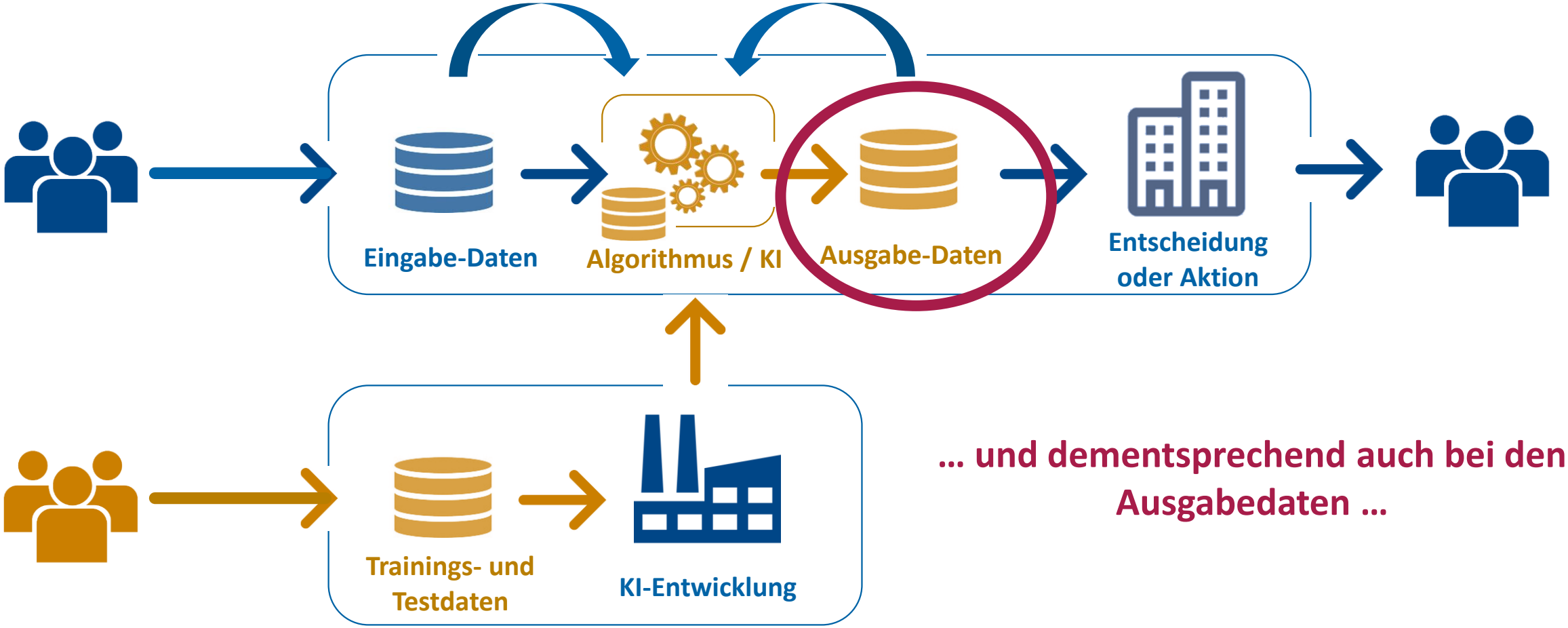

Eingabe-Daten
Algorithmus / KI
Ausgabe-Daten
Entscheidung oder Aktion
Trainings- und Testdaten
KI-Entwicklung



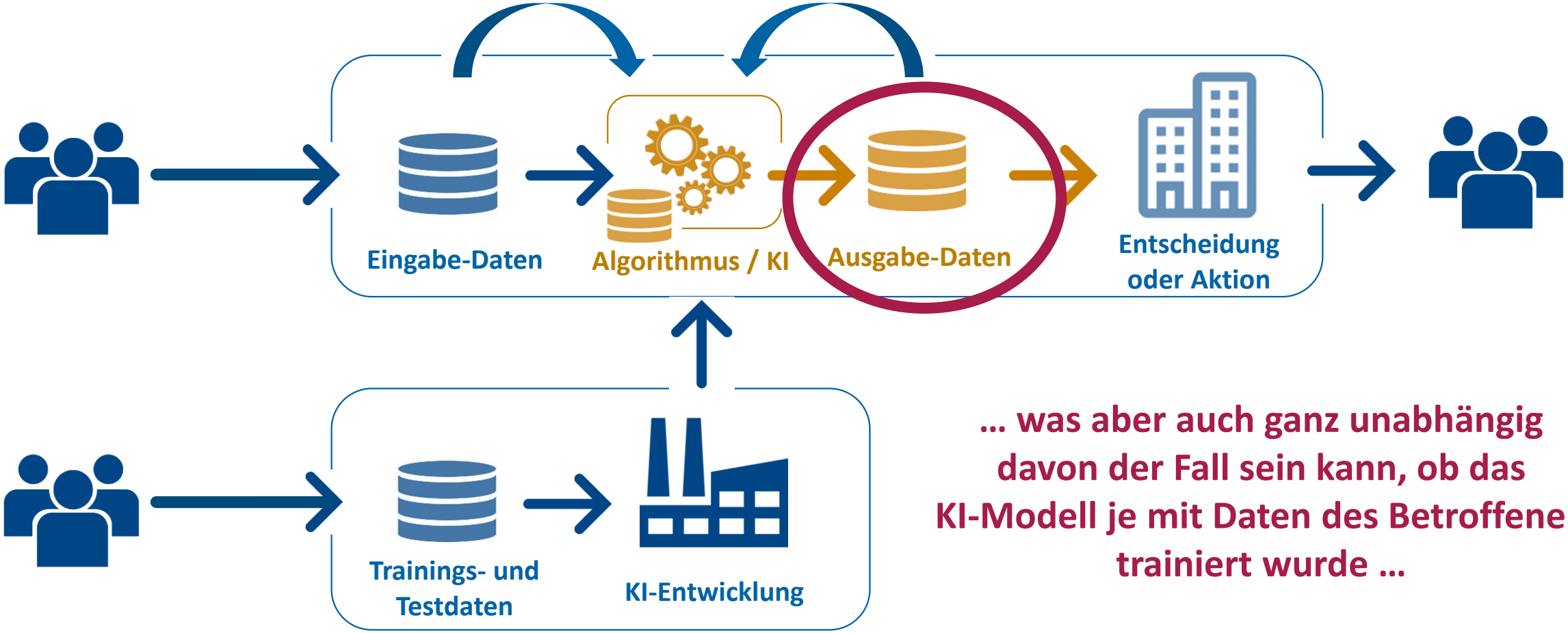
Problem der sicheren Rechtsgrundlage (Art. 6 und 9 DSGVO) bei großen und heterogenen Datensätzen



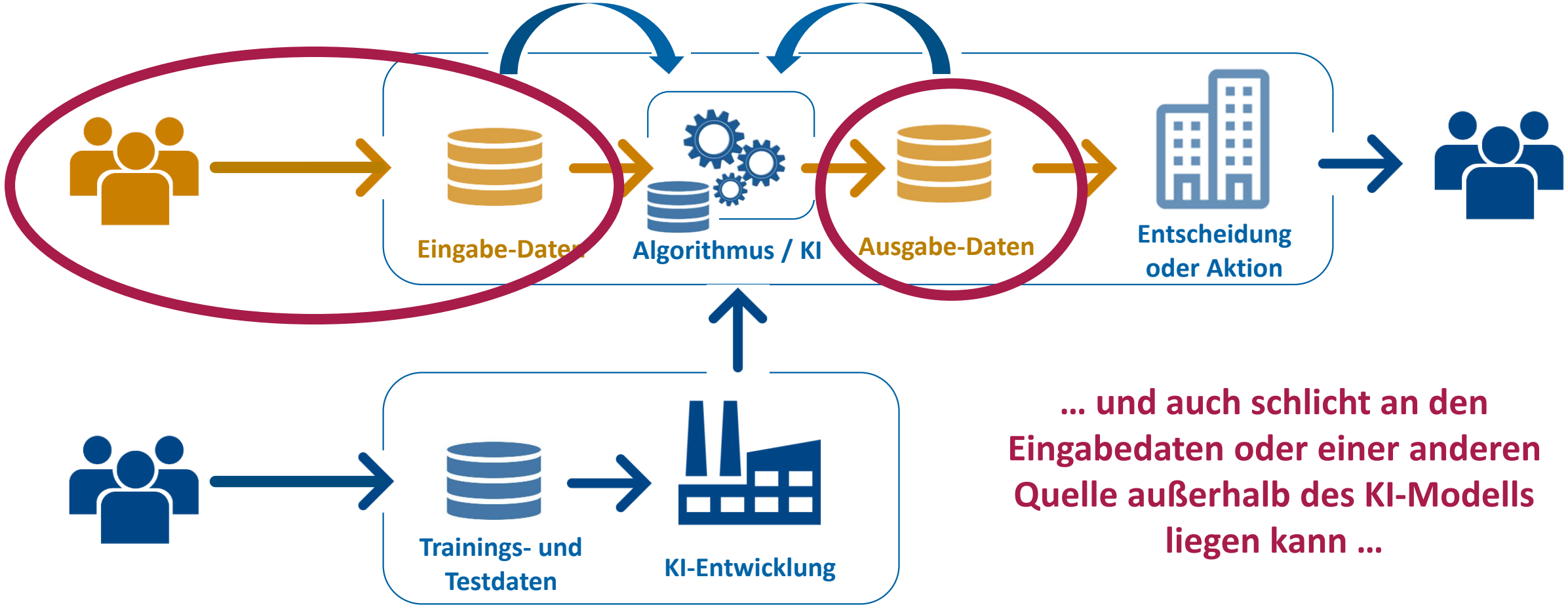
Frage nach Rechtsgrundlage und Ausübung von Betroffenenrechten bei „memorisierten“ personenbezogenen Daten „im“ KI-Modell …



… und dementsprechend auch bei den Ausgabedaten …

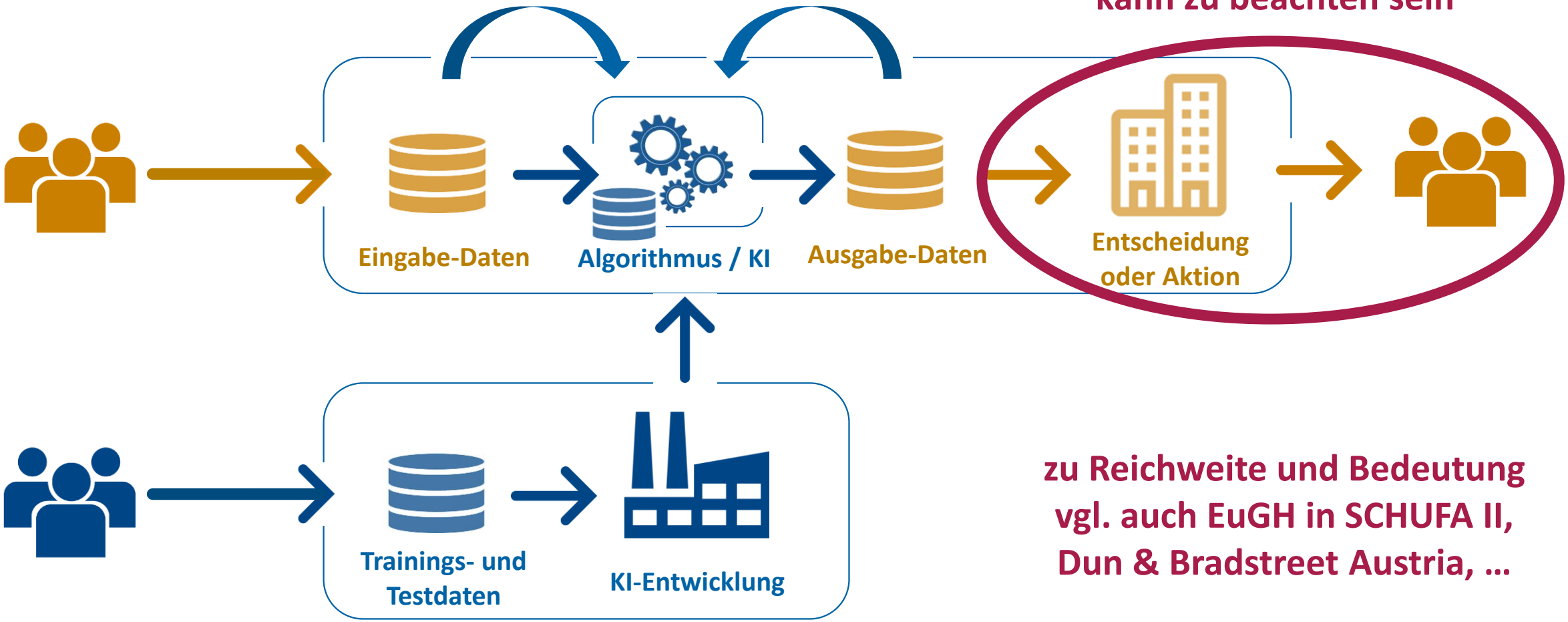


… was aber auch ganz unabhängig davon der Fall sein kann, ob das KI-Modell je mit Daten des Betroffenen trainiert wurde …



… und auch schlicht an den Eingabedaten oder einer anderen Quelle außerhalb des KI-Modells liegen kann …

Art. 22 DSGVO zu automatisierten Entscheidungen kann zu beachten sein



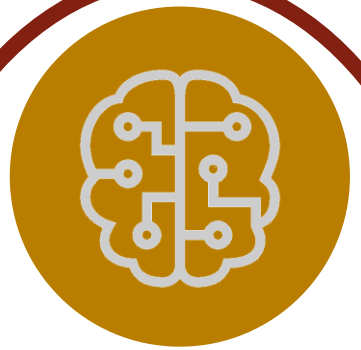
zu Reichweite und Bedeutung vgl. auch EuGH in SCHUFA II, Dun & Bradstreet Austria, …

Aktuelle Reformdiskussion

Wissenschaftlicher Diskussionsentwurf für eine „KI-Datenschutz-VO“ (Dezember 2024)

Bestimmte Datennutzungen schlicht verbieten – Betroffene müssen sich darauf verlassen können, dass sie einfach „OK“ klicken können, ohne dass wirklich Schlimmes passiert

Hochrisiko-Anwendungen großer Akteure (zB großer Plattformen) **verschärften Vorschriften unterwerfen**, zB Verpflichtung, mit Datentreuhändern zu kooperieren.

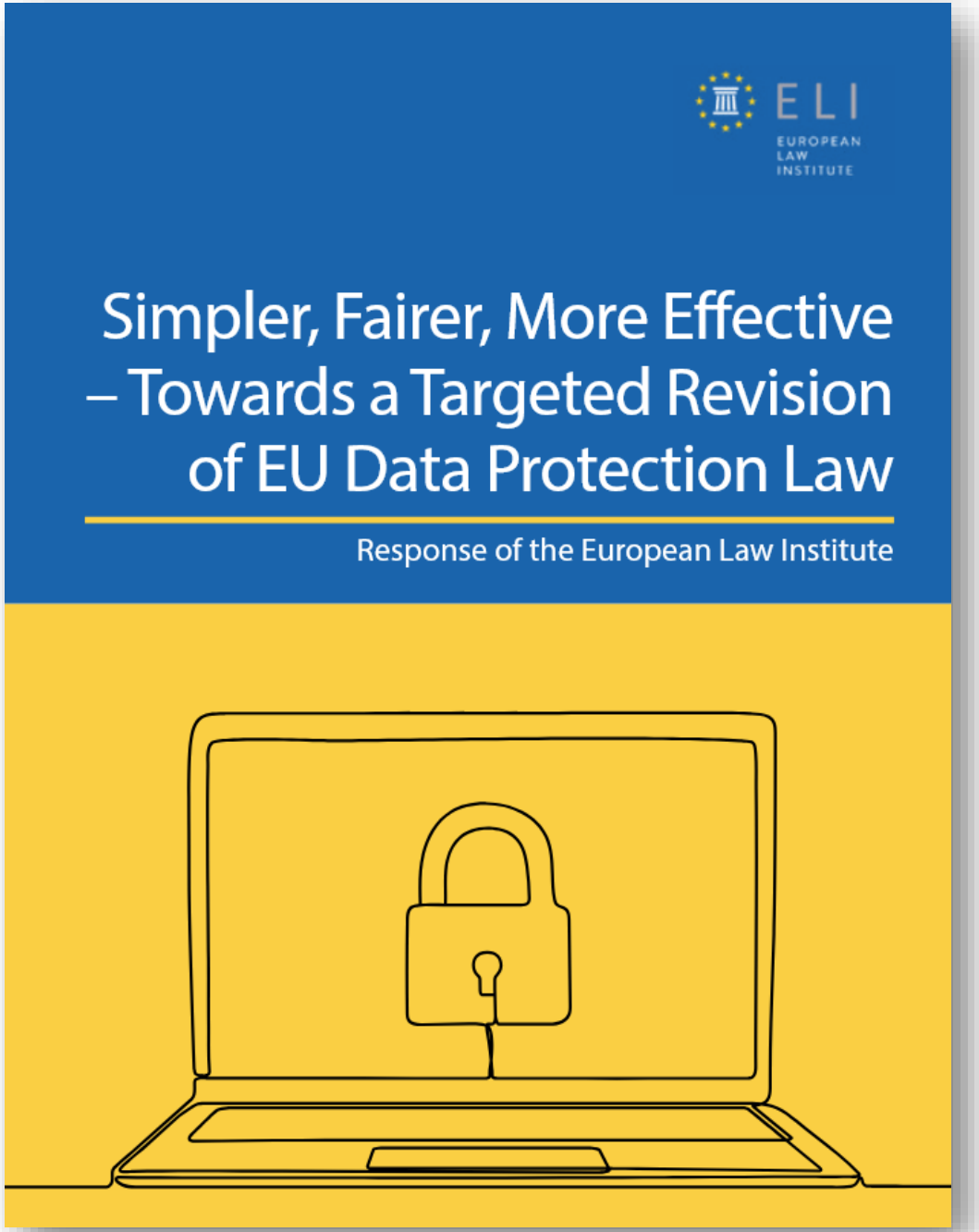


Unnötige Hindernisse für Datenwirtschaft und KI-Entwicklung in Europa beseitigen und den Rechtsrahmen an die Bedürfnisse und die Risiken großer KI-Modelle anpassen.

Kleine Akteure, die keine Hochrisiko-Anwendungen durchführen und nur ihrer gewöhnlichen Tätigkeit nachgehen, **aus dem Anwendungsbereich der DSGVO ganz herausnehmen**.

ELI's response to the consultation on the Digital Omnibus and Digital Package

published on
14 October 2025



Overview of proposals

1. Prohibiting very harmful data activities
2. Exempting minimal-risk processing
3. Concept of ‘small-scale’ controller and processor
4. A ‘light regime’ for other than high-risk processing
5. Fewer administrative burdens in the context of engaging data processors
6. Concept of ‘large-scale’ controller and processor
7. List of high-risk data processing operations
8. Better protection by enabling effective consent management
9. Visibility and traceability of data traders
10. Mandatory audits for the very large players
11. Restricting Article 9 to sensitive processing operations
12. Additional grounds for the permitted processing of special categories of p data
13. Legal basis for training AI and similar activities
14. More targeted data subject rights in the context of AI
15. A new conflict of laws provision
16. Centralising certain tasks of supervisory authorities
17. A harmonised illustrative list of legitimate interests

Der „Digitale Omnibus“

Omnibus I

Simplification of the CBAM
+
Sustainable Finance Omnibus (CSRD/CSDDD)

Omnibus II

InvestEU

Omnibus III

Simplifying implementation of CAP Strategic Plans

Omnibus IV

Digitalisation and common specifications
+
Small Mid Caps

Omnibus V

Defence Readiness

Omnibus VI

Simplification for chemicals legislation

Omnibus VII

Digital Simplification Package

Omnibus VIII

Environmental legislation package

Omnibus IX

Automotive

Omnibus IX

Food and feed safety requirements

Vorschläge zu Datenschutz und KI im Digitalen Omnibus

- Bisheriger Art. 10 Abs. 5 KI-VO zur Verarbeitung sensibler Kategorien von Daten soll auf alle KI-Systeme erweitert und in einen neuen Art. 4a transferiert werden (Warum keine Regelung in Art. 9 DSGVO??)
- Neue Regelung zur Rechtsgrundlage, im Wesentlichen identisch mit Art. 6 Abs. 1 lit. f DSGVO in neuem Art. 88c DSGVO (Warum eine eigene Regelung speziell für KI-Systeme iSd KI-VO??)
- Entwicklung und Nutzung von KI-Systemen iSd KI-VO allgemein unter Art. 9 Abs. 2 DSGVO privilegiert (warum??), aber eingeschränkt durch neuen Art. 9 Abs. 5 DSGVO, der inspiriert ist von einem Urteil des OLG Köln aus 2025
- Klarstellung, dass wissenschaftliche Forschung auch industrielle Forschung umfasst
- …

Ex-post Feedback zum Digitalen Omnibus

Simplification – digital package and omnibus

Have your say - Public Consultations and Feedback > Published initiatives > Simplification – digital package and omnibus

In preparation

Call for evidence

Feedback period

16 September 2025 - 14 October 2025

Feedback: Closed

Commission adoption

Feedback period

21 November 2025 - 13 March 2026

Feedback: Open

About this initiative

Summary

The digital package will set out the Commission's simplification agenda for the years to come. Based on feedback from 3 public consultations, it will include a digital omnibus with a first set of measures to quickly reduce the burden on businesses.

These measures focus on:

- data legislation, including rules on cookies and other tracking technologies
- cybersecurity incident reporting
- targeted adjustments to the Artificial Intelligence Act to ensure the optimal application of the rules.

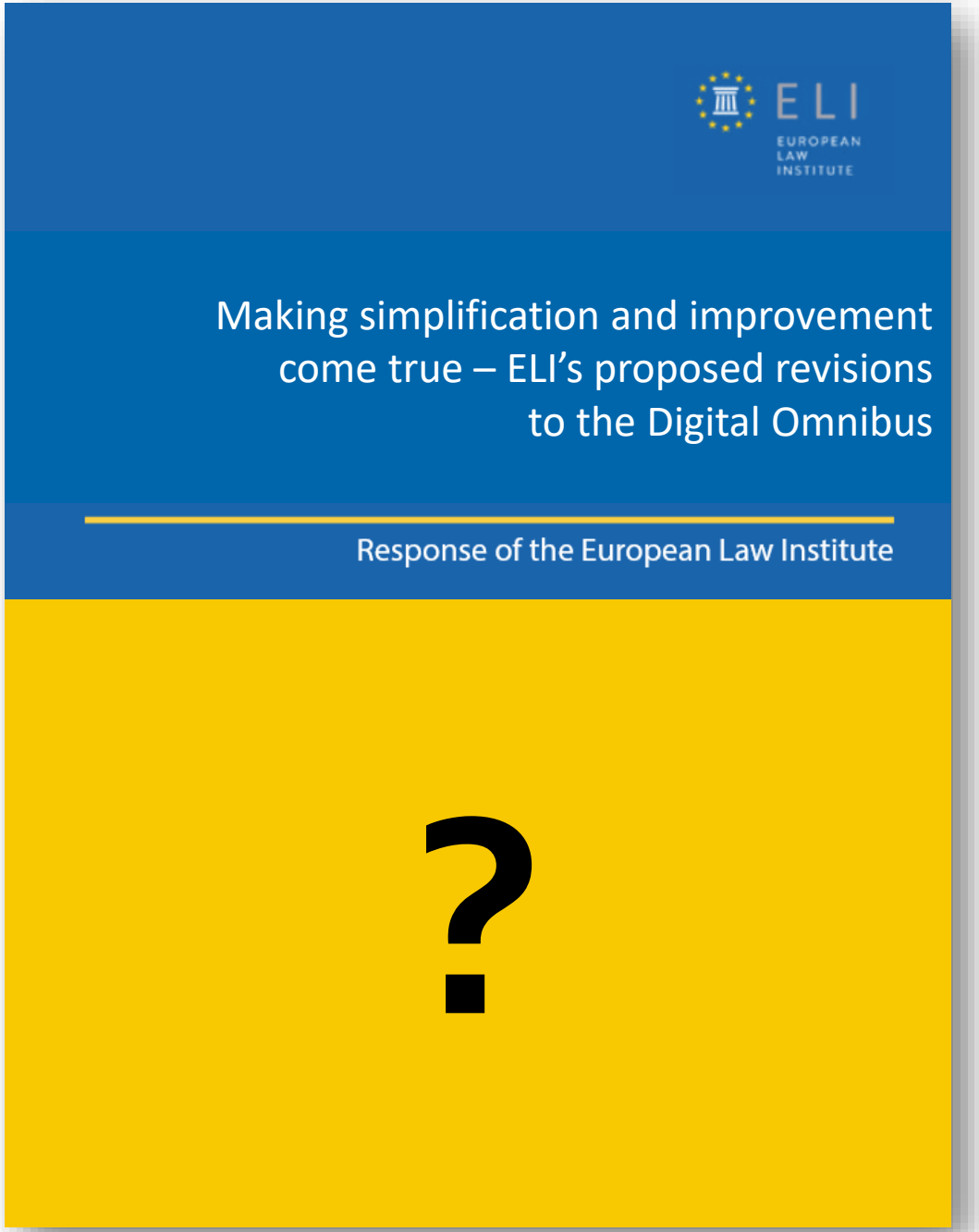
Topic Digital economy and society

Type of act Proposal for a regulation

Category Commission Work Programme, REFIT

ELI's response to the ex-post consultation on the Digital Omnibus

In the event of a postive ELI Council vote to be published on 11 or 12 March 2026



ELI
EUROPEAN LAW INSTITUTE

Parties' roles with regard to AI output and AI models are clarified

Article 88d
Personal data in output

1. Whether or not a natural person's personal data were used in developing a technical solution based on aggregated data, including an AI system or model, any output is to be treated as personal data in respect of a natural person if it can reasonably be related to that identified or identifiable person.
2. The party determining the purposes and means of processing the output, including by initiating its generation, using or storing it, shall be a controller of the personal data contained therein.
3. A provider, including a downstream provider, shall equally be considered as a controller with regard to the generation of output where
    a. the output, or output containing similar personal data with regard to the data subject, is generated in a systematic manner; and
    b. the information relating to the data subject was not provided by a downstream source beyond the control of the provider.
4. Where points a and b of paragraph 3 are fulfilled, a party controlling the system or model shall have the same obligations as that party would have if the generable output was processed as actual data under the control of that party.

Trustworthy and privacy-preserving AI enjoys a privilege …

Article 88c

Processing in the context of AI and similar technologies

1. Processing of personal data for the development, provision, or use of technical solutions based on aggregated data, including AI systems or models, shall be deemed to be in conformity with this Regulation, where all of the following requirements are met:

    a. the development, provision or use as such serves a legitimate interest pursued by the controller or by a third party, and such interests are not overridden by the interests or fundamental rights and freedoms of the data subjects which require protection of personal data; and

    b. appropriate safeguards, such as privacy-preserving upstream technical and organisational measures, have been applied which ensure that

        i. it is not possible to re-identify the data subjects from the resulting system or model with any means reasonably likely to be used, except where there is a legal ground in Article 6(1) and, where relevant, Article 9(2); and

        ii. the principles set forth in Article 5 are complied with to a degree that is reasonable in the circumstances, in particular the principle of lawfulness, fairness, and transparency.

ELI EUROPEAN LAW INSTITUTE

… and is protected if something goes wrong or data subjects exercise their rights

2. Where, despite the implementation of appropriate safeguards within the meaning of point b of paragraph 1, the controller learns of any personal data for whose processing there is no legal ground in Article 6(1) and, where relevant, Article 9(2), the controller shall remove such data. This applies to personal data at every stage of the lifecycle of the system or model, including to training, validation and testing data as well as input and output data.

3. If removal of relevant personal data within the meaning of paragraph 2, or compliance with any of the rights under Articles 16 to 18, 20 and 21 exercised by a data subject, requires effort that is disproportionate, the controller shall in any event

   a. without undue delay implement appropriate safeguards, such as downstream technical and organisational measures, to prevent relevant personal data from being used or generated as output by the system or model; and

   b. remove the data or comply with any of the data subjects' rights as soon as this is possible with proportionate effort, such as upon the next major revision of the system or model.

   In determining proportionate effort, factors to be taken into account include the potential risk posed for data subjects, the efforts actually required and what they mean for the controller, the amount of investment made, and the compliance with data protection and other law in developing the technology, and the purposes for which the technology has been created.

universität wien

Vielen Dank für Ihre Aufmerksamkeit!

Univ.-Prof. Dr. Dr. h.c. Christiane Wendehorst, LL.M.